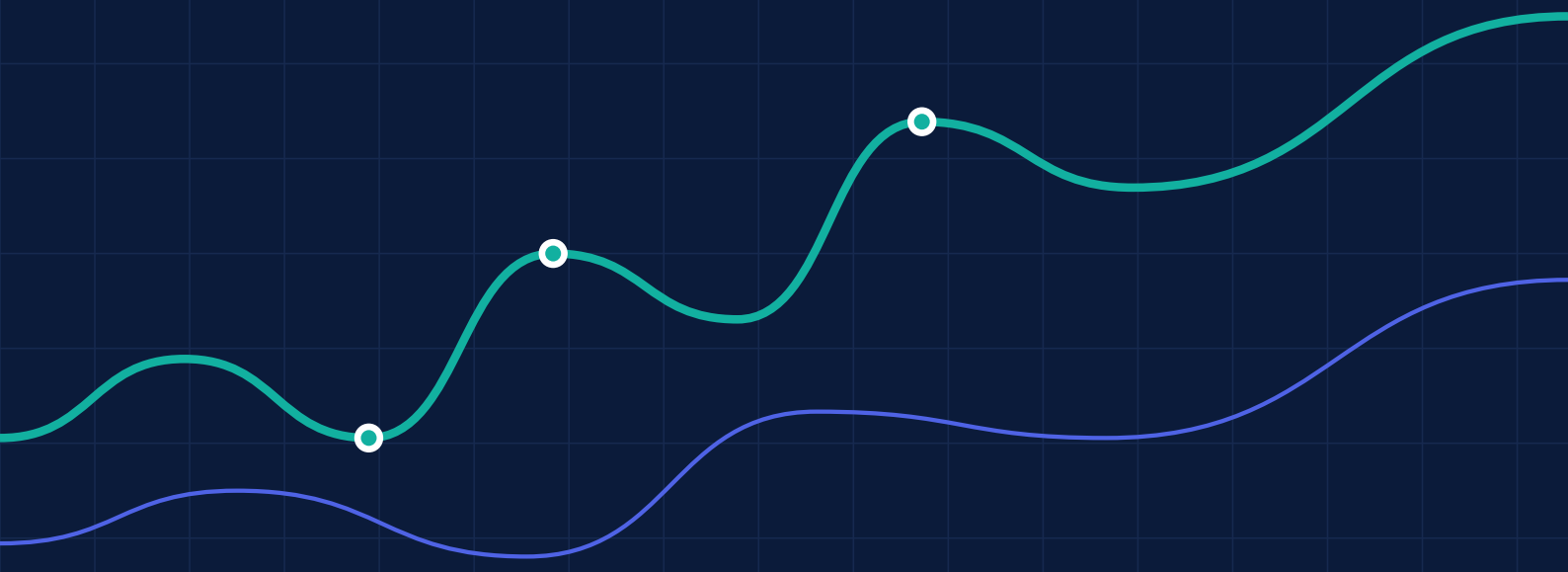
PricePilot AI
Dynamic Pricing & Revenue Intelligence

QUALITY ASSURANCE / BACKEND

API Testing Report

Functional, authorization and validation results for every REST endpoint of the PricePilot AI backend, run against the real datasets.



117	43	97.4%	4
test cases run	endpoints covered	pass rate	findings logged

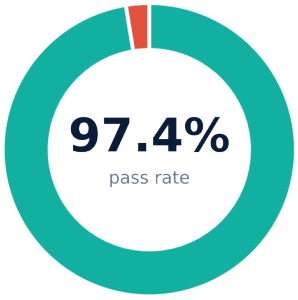
Report date: 16 October 2026 | Build under test: pricepilot-ai v1.0.0

OVERVIEW

Executive summary

We ran **117 test cases** across **43 API endpoints** of the PricePilot AI backend. Each case called the live FastAPI server with real credentials, against the four supplied datasets (69 products, 43,245 operations rows, 92,668 customer events, 18,848 competitor prices). **114 passed and 3 failed**. All three failures come from defects in the application, not from the test harness. Core business endpoints (KPIs, price optimization, demand forecasting, competitor and customer analytics, reports, chat) returned 200 with data-backed responses. One of the failures is a **privilege escalation** that should be fixed before anyone else uses the app.

117	114	3	15 / 15
test cases executed	passed	failed	unit tests passed (pytest)



Release verdict

Not ready for shared use. The application works end to end on real data, but open self-registration lets anyone create an ADMIN account (Finding F1). Fix that, then retest.

What passed

Login and token validation, 403 for blocked roles across every restricted module, 422 for malformed bodies on auth, pricing, forecast, chat and dashboard calls, 404 for unknown products, a SQL injection probe, and the AI fallback to deterministic output.

What failed

Open ADMIN self-registration; unsupported report format causes a 500; unknown report id returns 200 instead of 404. A fourth defect was found in the test suite itself (see F2).

Results by module



HOW WE TESTED

Scope, environment and method

Item	Detail
Application	PricePilot AI backend, FastAPI 0.115+, SQLAlchemy 2.0, JWT (HS256) with bcrypt
Database	SQLite test database loaded from the real CSVs. **PostgreSQL was not used in this run.**
Data	product_catalog (69), daily_operations (43,245), customer_activity (92,668), competitor_prices (18,848)
Models	Price: Random Forest (test R2 0.994, MAE 6.99). Demand: XGBoost per product, 15 products evaluated
Client	Python httpx against the running Uvicorn server on localhost (real HTTP, not in-process calls)
AI providers	No Groq or Gemini key was configured, so the deterministic fallback path was tested. Live LLM calls were not tested.
Users	Four accounts, one per role: ADMIN, BUSINESS_MANAGER, BUSINESS_ANALYST, VIEWER

Test design

Every endpoint was exercised with the same four kinds of case, where they apply:

Case type	What we send	Expected
Happy path	Valid request from a permitted role	200 with a data-backed body
Authentication	No token or a tampered token	401
Authorization	Valid token from a role that should be blocked	403
Validation	Bad types, missing fields, bad enums, unknown ids	400, 404 or 422, never 500

Role permissions as implemented

Capability	ADMIN	MANAGER	ANALYST	VIEWER
Dashboard, products, reports, model metrics (read)	Allowed	Allowed	Allowed	Allowed
Pricing, forecasting, competitors, customers	Allowed	Allowed	Allowed	Blocked
AI recommendations, alerts, copilot chat	Allowed	Allowed	Allowed	Blocked
Revenue optimization	Allowed	Allowed	Blocked	Blocked
EDA and insights	Allowed	Blocked	Allowed	Blocked
Users, audit logs, model training	Allowed	Blocked	Blocked	Blocked

Each blocked cell above was tested with a real token for that role and returned 403. The one exception is F1, where a self-registered account was able to obtain ADMIN rights.

INVENTORY

Endpoint coverage

43 unique method and path combinations were tested. Path parameters are shown as placeholders.

Method	Endpoint	Module	Cases	Passed
POST	/api/auth/login	Authentication	2	2/2
POST	/api/auth/logout	Authentication	1	1/1
GET	/api/auth/me	Authentication	3	3/3
POST	/api/auth/register	Authentication	7	7/7
GET	/api/health	System	1	1/1
GET	/api/users	Users	4	3/4
PATCH	/api/users/{id}/role	Users	4	4/4
PATCH	/api/users/{id}/status	Users	1	1/1
GET	/api/products	Products	6	6/6
GET	/api/products/{product_id}	Products	2	2/2
GET	/api/dashboard/breakdown	Dashboard	2	2/2
GET	/api/dashboard/filters/options	Dashboard	1	1/1
GET	/api/dashboard/kpis	Dashboard	5	5/5
GET	/api/dashboard/top-products	Dashboard	1	1/1
GET	/api/dashboard/trend	Dashboard	2	2/2
GET	/api/pricing/history/{product_id}	Pricing	1	1/1
POST	/api/pricing/optimize	Pricing	7	7/7
POST	/api/pricing/predict	Pricing	2	2/2
POST	/api/forecast/demand	Forecasting	6	6/6
GET	/api/forecast/{product_id}	Forecasting	1	1/1
GET	/api/competitors	Market Intelligence	2	2/2
GET	/api/competitors/{product_id}	Market Intelligence	1	1/1
GET	/api/customers/analytics	Market Intelligence	3	3/3
GET	/api/revenue/optimize/{id}	Revenue	1	1/1
GET	/api/revenue/optimize/{product_id}	Revenue	2	2/2
GET	/api/eda/distribution	EDA	2	2/2
GET	/api/eda/summary	EDA	6	6/6
GET	/api/ai/recommendations	AI Intelligence	1	1/1
POST	/api/ai/recommendations	AI Intelligence	3	3/3
GET	/api/alerts	AI Intelligence	4	4/4
POST	/api/alerts/generate	AI Intelligence	1	1/1
PATCH	/api/alerts/{id}/archive	AI Intelligence	1	1/1
PATCH	/api/alerts/{id}/read	AI Intelligence	2	2/2
POST	/api/chat	Copilot Chat	6	6/6

Method	Endpoint	Module	Cases	Passed
GET	/api/chat/sessions	Copilot Chat	1	1/1
GET	/api/chat/sessions/{id}/messages	Copilot Chat	1	1/1
GET	/api/reports	Reports	1	1/1
POST	/api/reports/generate	Reports	5	4/5
GET	/api/reports/{id}/download	Reports	4	3/4
GET	/api/audit	Administration	2	2/2
GET	/api/models/performance	Model Management	1	1/1
POST	/api/models/train/demand	Model Management	2	2/2
POST	/api/models/train/price	Model Management	2	2/2

TEST CASES

Detailed results by module

Exp. is the expected HTTP status and Got is what the server returned. Times are wall-clock milliseconds including the Python client.

Authentication

12/12 passed

Method	Endpoint	Test case	Role	Exp.	Got	ms	Result
POST	/api/auth/register	Register BUSINESS_MANAGER	Public	200	**200**	309	PASS
POST	/api/auth/register	Register BUSINESS_ANALYST	Public	200	**200**	316	PASS
POST	/api/auth/register	Register VIEWER	Public	200	**200**	322	PASS
POST	/api/auth/login	Login (valid)	Public	200	**200**	308	PASS
POST	/api/auth/login	Login (wrong password)	Public	401	**401**	302	PASS
POST	/api/auth/register	Register duplicate email	Public	400	**400**	4	PASS
POST	/api/auth/register	Register short password	Public	422	**422**	2	PASS
POST	/api/auth/register	Register invalid email	Public	422	**422**	2	PASS
GET	/api/auth/me	Current user (/me)	Any	200	**200**	4	PASS
GET	/api/auth/me	/me without token	Public	401	**401**	1	PASS
GET	/api/auth/me	/me with tampered token	Public	401	**401**	2	PASS
POST	/api/auth/logout	Logout	Any	200	**200**	7	PASS

System

5/5 passed

Method	Endpoint	Test case	Role	Exp.	Got	ms	Result
GET	/	Root	Public	200	**200**	3	PASS
GET	/api/health	Health check	Public	200	**200**	2	PASS
GET	/openapi.json	OpenAPI schema	Public	200	**200**	53	PASS
GET	/docs	Swagger UI	Public	200	**200**	2	PASS
GET	/redoc	ReDoc	Public	200	**200**	1	PASS

Users

8/8 passed

Method	Endpoint	Test case	Role	Exp.	Got	ms	Result
GET	/api/users	List users	ADMIN	200	**200**	5	PASS
GET	/api/users	List users (VIEWER blocked)	VIEWER	403	**403**	4	PASS
GET	/api/users	List users (no token)	Public	401	**401**	2	PASS
PATCH	/api/users/{id}/role	Change role	ADMIN	200	**200**	10	PASS
PATCH	/api/users/{id}/role	Change role (invalid role)	ADMIN	400	**400**	5	PASS
PATCH	/api/users/{id}/role	Change role (unknown user)	ADMIN	404	**404**	4	PASS
PATCH	/api/users/{id}/role	Change role (MANAGER blocked)	MANAGER	403	**403**	3	PASS
PATCH	/api/users/{id}/status	Toggle status	ADMIN	200	**200**	8	PASS

Products

6/6 passed

Method	Endpoint	Test case	Role	Exp.	Got	ms	Result
GET	/api/products	List products	VIEWER	200	**200**	16	PASS
GET	/api/products	Search products	VIEWER	200	**200**	10	PASS
GET	/api/products	Filter by category	VIEWER	200	**200**	11	PASS
GET	/api/products	List (no token)	Public	401	**401**	2	PASS
GET	/api/products/{product_id}	Product detail P1000	VIEWER	200	**200**	1,747	PASS
GET	/api/products/{product_id}	Product detail (not found)	VIEWER	404	**404**	6	PASS

Dashboard

11/11 passed

Method	Endpoint	Test case	Role	Exp.	Got	ms	Result
GET	/api/dashboard/kpis	KPIs	VIEWER	200	**200**	1,620	PASS
GET	/api/dashboard/kpis	KPIs filtered (category)	VIEWER	200	**200**	199	PASS
GET	/api/dashboard/kpis	KPIs filtered (date range)	VIEWER	200	**200**	376	PASS
GET	/api/dashboard/kpis	KPIs invalid date	VIEWER	422	**422**	6	PASS
GET	/api/dashboard/kpis	KPIs (no token)	Public	401	**401**	3	PASS
GET	/api/dashboard/trend	Trend (revenue)	VIEWER	200	**200**	580	PASS
GET	/api/dashboard/trend	Trend (price)	VIEWER	200	**200**	690	PASS
GET	/api/dashboard/breakdown	Breakdown by category	VIEWER	200	**200**	538	PASS
GET	/api/dashboard/breakdown	Breakdown by channel	VIEWER	200	**200**	530	PASS
GET	/api/dashboard/top-products	Top products	VIEWER	200	**200**	663	PASS
GET	/api/dashboard/filters/options	Filter options	VIEWER	200	**200**	20	PASS

Pricing

10/10 passed

Method	Endpoint	Test case	Role	Exp.	Got	ms	Result
POST	/api/pricing/predict	Predict price	ANALYST	200	**200**	776	PASS
POST	/api/pricing/predict	Predict (unknown product)	ANALYST	404	**404**	248	PASS
POST	/api/pricing/optimize	Optimize (revenue)	ANALYST	200	**200**	577	PASS
POST	/api/pricing/optimize	Optimize (profit)	ANALYST	200	**200**	549	PASS
POST	/api/pricing/optimize	Optimize (demand)	ANALYST	200	**200**	549	PASS
POST	/api/pricing/optimize	Optimize (competitive)	ANALYST	200	**200**	556	PASS
POST	/api/pricing/optimize	Optimize (invalid body)	ANALYST	422	**422**	4	PASS
POST	/api/pricing/optimize	Optimize (unknown product)	ANALYST	404	**404**	256	PASS
POST	/api/pricing/optimize	Optimize (VIEWER blocked)	VIEWER	403	**403**	4	PASS
GET	/api/pricing/history/{product_id}	Prediction history	ANALYST	200	**200**	7	PASS

Forecasting

7/7 passed

Method	Endpoint	Test case	Role	Exp.	Got	ms	Result
POST	/api/forecast/demand	Forecast 7 days (POST)	ANALYST	200	200	754	PASS
POST	/api/forecast/demand	Forecast 30 days (POST)	ANALYST	200	200	757	PASS
POST	/api/forecast/demand	Forecast 365 days (POST)	ANALYST	200	200	1,498	PASS
GET	/api/forecast/{product_id}	Forecast (GET)	ANALYST	200	200	726	PASS
POST	/api/forecast/demand	Forecast (unknown product)	ANALYST	404	404	292	PASS
POST	/api/forecast/demand	Forecast (VIEWER blocked)	VIEWER	403	403	5	PASS
POST	/api/forecast/demand	Forecast (missing field)	ANALYST	422	422	4	PASS

Market Intelligence

6/6 passed

Method	Endpoint	Test case	Role	Exp.	Got	ms	Result
GET	/api/competitors	All competitor analysis	ANALYST	200	200	718	PASS
GET	/api/competitors/{product_id}	Competitor analysis P1000	ANALYST	200	200	776	PASS
GET	/api/competitors	Competitors (VIEWER blocked)	VIEWER	403	403	4	PASS
GET	/api/customers/analytics	Customer analytics	ANALYST	200	200	771	PASS
GET	/api/customers/analytics	Customer analytics (category)	ANALYST	200	200	122	PASS
GET	/api/customers/analytics	Customer analytics (VIEWER blocked)	VIEWER	403	403	4	PASS

Revenue

3/3 passed

Method	Endpoint	Test case	Role	Exp.	Got	ms	Result
GET	/api/revenue/optimize/{product_id}	Revenue scenarios P1000	MANAGER	200	200	553	PASS
GET	/api/revenue/optimize/{id}	Revenue scenarios (unknown)	MANAGER	404	404	5	PASS
GET	/api/revenue/optimize/{product_id}	Revenue scenarios (ANALYST blocked)	ANALYST	403	403	3	PASS

EDA

8/8 passed

Method	Endpoint	Test case	Role	Exp.	Got	ms	Result
GET	/api/eda/summary	EDA summary (product_catalog)	ANALYST	200	200	19	PASS
GET	/api/eda/summary	EDA summary (daily_operations)	ANALYST	200	200	748	PASS
GET	/api/eda/summary	EDA summary (customer_activity)	ANALYST	200	200	1,027	PASS
GET	/api/eda/summary	EDA summary (competitor_prices)	ANALYST	200	200	86	PASS
GET	/api/eda/summary	EDA summary (unknown dataset)	ADMIN	400	400	5	PASS
GET	/api/eda/summary	EDA summary (MANAGER blocked)	MANAGER	403	403	4	PASS
GET	/api/eda/distribution	EDA distribution (numeric)	ADMIN	200	200	71	PASS
GET	/api/eda/distribution	EDA distribution (categorical)	ADMIN	200	200	72	PASS

AI Intelligence

12/12 passed

Method	Endpoint	Test case	Role	Exp.	Got	ms	Result
POST	/api/ai/recommendations	Generate recommendations	ANALYST	200	200	3,283	PASS
POST	/api/ai/recommendations	Generate recommendations (product)	ANALYST	200	200	1,864	PASS
GET	/api/ai/recommendations	List recommendations	ANALYST	200	200	26	PASS
POST	/api/ai/recommendations	Recommendations (VIEWER blocked)	VIEWER	403	403	5	PASS
POST	/api/alerts/generate	Generate alerts	ANALYST	200	200	2,711	PASS
GET	/api/alerts	List alerts	ANALYST	200	200	12	PASS
GET	/api/alerts	List alerts (severity=CRITICAL)	ANALYST	200	200	8	PASS
GET	/api/alerts	Search alerts	ANALYST	200	200	7	PASS
PATCH	/api/alerts/{id}/read	Mark alert read	ANALYST	200	200	8	PASS
PATCH	/api/alerts/{id}/archive	Archive alert	ANALYST	200	200	7	PASS
PATCH	/api/alerts/{id}/read	Mark read (unknown id)	ANALYST	404	404	6	PASS
GET	/api/alerts	Alerts (VIEWER blocked)	VIEWER	403	403	4	PASS

Copilot Chat

8/8 passed

Method	Endpoint	Test case	Role	Exp.	Got	ms	Result
POST	/api/chat	Ask: top revenue product	ANALYST	200	200	729	PASS
POST	/api/chat	Ask: forecast P1000	ANALYST	200	200	485	PASS
POST	/api/chat	Ask: price for P1000	ANALYST	200	200	531	PASS
POST	/api/chat	Ask: stockout risk	ANALYST	200	200	493	PASS
POST	/api/chat	Chat (empty body)	ANALYST	422	422	5	PASS
POST	/api/chat	Chat (VIEWER blocked)	VIEWER	403	403	4	PASS
GET	/api/chat/sessions	List sessions	ANALYST	200	200	5	PASS
GET	/api/chat/sessions/{id}/messages	Session messages	ANALYST	200	200	7	PASS

Reports

8/10 passed

Method	Endpoint	Test case	Role	Exp.	Got	ms	Result
POST	/api/reports/generate	Generate executive report (pdf)	VIEWER	200	200	4,480	PASS
GET	/api/reports/{id}/download	Download PDF report	VIEWER	200	200	11	PASS
POST	/api/reports/generate	Generate pricing report (xlsx)	VIEWER	200	200	4,623	PASS
GET	/api/reports/{id}/download	Download XLSX report	VIEWER	200	200	5	PASS
POST	/api/reports/generate	Generate revenue report (csv)	VIEWER	200	200	4,755	PASS
GET	/api/reports/{id}/download	Download CSV report	VIEWER	200	200	6	PASS
POST	/api/reports/generate	Generate (unsupported format)	VIEWER	422	500	4,605	FAIL
POST	/api/reports/generate	Generate (no token)	Public	401	401	12	PASS
GET	/api/reports	Report history	VIEWER	200	200	7	PASS
GET	/api/reports/{id}/download	Download (unknown id)	VIEWER	404	200	4	FAIL

Administration

2/2 passed

Method	Endpoint	Test case	Role	Exp.	Got	ms	Result
GET	/api/audit	Audit logs	ADMIN	200	200	6	PASS
GET	/api/audit	Audit logs (MANAGER blocked)	MANAGER	403	403	4	PASS

Model Management

5/5 passed

Method	Endpoint	Test case	Role	Exp.	Got	ms	Result
GET	/api/models/performance	Model performance	VIEWER	200	**200**	4	PASS
POST	/api/models/train/price	Train price (ANALYST blocked)	ANALYST	403	**403**	3	PASS
POST	/api/models/train/demand	Train demand (ANALYST blocked)	ANALYST	403	**403**	3	PASS
POST	/api/models/train/price	Train price model	ADMIN	200	**200**	32,420	PASS
POST	/api/models/train/demand	Evaluate / train demand model	ADMIN	200	**200**	6,649	PASS

Security Probes

3/4 passed

Method	Endpoint	Test case	Role	Exp.	Got	ms	Result
POST	/api/auth/register	Self-register as ADMIN (privilege check)	Public	200	**200**	305	PASS
GET	/api/users	Self-registered account reads /api/users	ADMIN?	403	**200**	4	FAIL
GET	/api/products	SQL-injection string in product search	VIEWER	200	**200**	5	PASS
GET	/api/products	Products still intact after injection attempt	VIEWER	200	**200**	5	PASS

RESPONSE TIMES

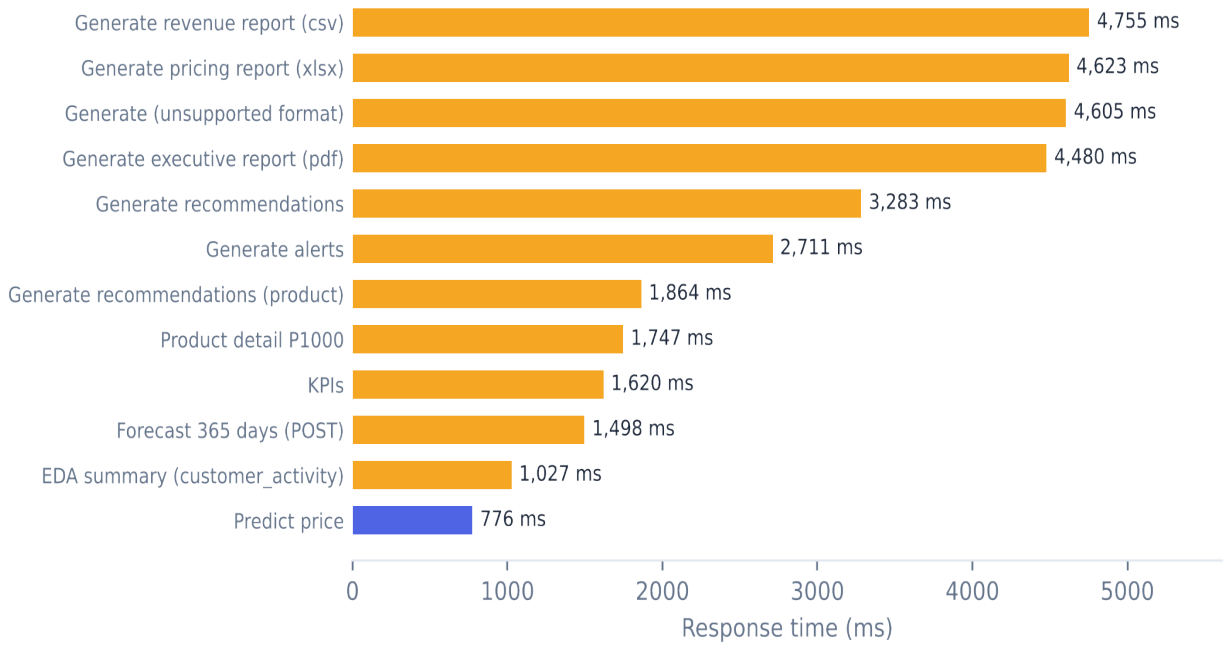
Performance snapshot

11 ms
median response

1,864 ms
95th percentile

4,755 ms
slowest non-training call

39 s
model training, total



Twelve slowest calls, excluding the two model-training endpoints. Amber bars are above one second.

What this tells us

Report generation was the slowest operation at about 4.6 seconds for every format, because each request recomputes KPIs, breakdowns, competitor and customer analytics from the database before writing the file. Alert and AI recommendation generation come next at 2 to 3 seconds. Model training took 32.4 s (price) and 6.6 s (demand evaluation). Everything else answered in under two seconds. This was a single-user run, not a load test. If response time matters, compute report aggregates once and reuse them across formats.

Training endpoint	Time	Status
`POST /api/models/train/price`	32.4 s	200
`POST /api/models/train/demand`	6.6 s	200

DEFECTS

Findings and recommended fixes

F1 Anyone can register as ADMIN — HIGH

Evidence	POST /api/auth/register accepts a role field from the caller. We registered evil@t.com with role ADMIN, logged in, and GET /api/users returned 200 with every user's email.
Impact	Full privilege escalation. A stranger gets user management, audit logs and model training.
Fix	Ignore role on the public endpoint and always create VIEWER. Let only an ADMIN change roles, which PATCH /api/users/{id}/role already does.

F2 Running pytest overwrites the real processed data — MEDIUM

Evidence	tests/test_pricing_forecast.py writes 90 synthetic rows to data/processed/feature_table.csv. After one pytest run the real 43,245-row file was gone and POST /api/pricing/optimize returned 404 for P1000.
Impact	A routine test run silently breaks price prediction and forecasting until prepare_data.py is rerun.
Fix	Point the fixture at a temporary directory (pytest tmp_path plus a monkeypatched PROCESSED_DIR) and never write into data/processed.

F3 Unsupported report format returns 500 — MEDIUM

Evidence	POST /api/reports/generate with file_format docx raised an unhandled ValueError. The server returned 500 and the next request on the same connection failed with ReadError.
Impact	Bad client input should be a 4xx. A 500 also pollutes logs and can drop keep-alive connections.
Fix	Type file_format as Literal['pdf','xlsx','csv'] in the Pydantic schema so FastAPI returns 422 automatically.

F4 Unknown report id returns 200 with an error body — LOW

Evidence	GET /api/reports/nope/download returned HTTP 200 and {"error": "Report not found"}.
Impact	Clients that trust the status code will treat a missing report as success.
Fix	Raise HTTPException(404). Also return 404 if the file path is recorded but the file no longer exists on disk.

SUPPORTING EVIDENCE

Unit tests and sample responses

Automated unit suite (pytest)

File	Covers	Result
`test_auth.py`	Login, wrong password, no token, admin-only route blocks VIEWER and allows ADMIN, VIEWER reads dashboard	PASS
`test_kpis_products.py`	KPIs are computed (profit = revenue - cost), product list, 404, invalid input 422	PASS
`test_pricing_forecast.py`	Price optimization, unknown product 404, forecast confidence score and trend label bounds	PASS
`test_ai_fallback.py`	Deterministic fallback for recommendations and chat when Groq and Gemini are unavailable	PASS

15 tests, 15 passed in 4.8 s. These use a small synthetic fixture inside tests/, as the project rules allow. Note finding F2.

Sample: GET /api/dashboard/kpis

Metric	Value	Metric	Value
Total revenue	**$326,607,206**	Estimated margin	**26.2%**
Units sold	**1,126,673**	Avg competitor price	**$380.94**
Active products	**69**	Competitor price gap	**$-76.49**
Conversion rate	**15.03%**	Stockout rate	**0.0%**

Sample: POST /api/pricing/optimize (P1000, revenue objective)

Current price	Recommended	Change	Expected demand	Expected revenue	Elasticity
$173.43	**$150.88**	**-13.0%**	**41.77**	**$6,303**	**-1.341**

Sample: POST /api/forecast/demand (P1000, 30 days)

Model	Trend	Confidence	Label	MAE	RMSE
xgboost	**Decreasing Demand**	**81.9%**	**High Confidence**	**11.30**	**15.37**

Sample: POST /api/chat (no LLM key configured)

The question "What is our top revenue product?" called the backend tool `top_products` and returned the retrieved rows directly through the deterministic fallback. No value was invented by a model.

CONCLUSION

Limits of this test and next steps

Not covered in this run

Area	Why it matters	Suggested follow-up
PostgreSQL	The production target. Types and SQL behave slightly differently from SQLite.	Rerun this suite via docker compose with Postgres.
Live Groq and Gemini	Only the fallback path was exercised, because no key was configured here.	Add keys to .env and retest recommendations and chat.
Load and concurrency	Single-user run. Per-request model fitting may not scale.	Run a Locust or k6 profile on forecast and KPI endpoints.
Frontend	This report covers the API only, not the React pages.	Add Playwright end-to-end checks for login and role visibility.
Token expiry	The 60 minute expiry was not waited out.	Add a test with a short-lived token.

Recommended order of work

1. **Fix F1 today.** It is a one-line change and the only blocker.
2. **Fix F2 next.** Otherwise every pytest run can break local price and forecast features.
3. **Fix F3 and F4.** Both are small validation changes.
4. **Rerun this suite.** The harness is repeatable, so a rerun takes a few minutes and should show 117 of 117.

Overall result **114 of 117 passed (97.4%)**. 4 findings: 1 high, 2 medium, 1 low.